

CS5294 Final Exam Review / 期末复习资料

Course / 课程: Information Security Technology Management / 信息安全技术管理
Instructor / 授课教师: Prof. Daniel TSE

1. Knowledge Framework / 知识框架

Session	Topic / 主题
1	Information Security Fundamentals & Traditional Attacks / 信息安全基础与传统攻击
2	InfoSec Management Principles & Threat Analysis / 信息安全管理原则与威胁分析
3	Security Technology: Cryptology / 安全技术: 密码学
4	Security Technology: Firewalls & VPN / 安全技术: 防火墙与VPN
5	Security Technology: IDPS & Other Security Tools / 安全技术: 入侵检测与其他工具
6	Information Security Policy / 信息安全策略
7	IT Risk Management / IT风险管理
8	Security Management Standards & Models / 安全管理标准与模型
9	Information Security Planning / 信息安全规划
10	Security Controls, Audit, Law & Ethics / 安全控制、审计、法律与伦理

2. Core Concepts / 核心概念梳理

Session 1: Information Security Fundamentals / 信息安全基础
Information Security (信息安全)

- Definition / 定义: A "well-informed sense of assurance that the information risks and controls are in balance" — Jim Anderson / 信息风险与控制达到平衡的良好保证感
- Key Points / 要点: Focuses on protecting information and its value characteristics (confidentiality, integrity, availability) through policy, training, awareness programs, and technology / 专注于通过策略、培训、意识项目和技术来保护信息及其价值特征

C.I.A. Triad (CIA三要素)

- Confidentiality (机密性): Protection from disclosure to unauthorized individuals or systems / 防止向未授权个人或系统泄露
- Measures: Information classification, secure storage, security policies, education, cryptography / 措施: 信息分类、安全存储、安全策略、教育、加密
- Integrity (完整性): Data is whole, complete, and uncorrupted / 数据完整、完全且未被篡改
- Threats: Corruption, damage, destruction of authentic state / 威胁: 篡改、损坏、真实状态的破坏
- Availability (可用性): Information is accessible to authorized users when needed / 授权用户需要时可访问信息

Additional Information Characteristics / 其他信息特征

- Privacy (隐私): Information collected, used, and stored appropriately / 信息被适当收集、使用和存储
- Identification (标识): Enables accountability by identifying users / 通过标识用户实现问责
- Authentication (认证): Verification of identity / 身份验证
- Authorization (授权): Providing authenticated users with appropriate access / 为已认证用户提供适当访问权限
- Accountability (问责性): All actions can be attributed to an authenticated identity / 所有行为可归属于已认证身份

Specialized Areas of Security / 安全专业领域

- Physical security / 物理安全
- Operations security / 操作安全
- Communications security / 通信安全
- Cyber (computer) security / 网络安全
- Network security / 网络安全

Traditional Attacks / 传统攻击方式

- Malware (恶意软件): Viruses, worms, Trojans, logic bombs, back doors / 病毒、蠕虫、木马、逻辑炸弹、后门
- Phishing (钓鱼攻击): Attempting to acquire sensitive information by posing as legitimate entity / 冒充合法实体获取敏感信息
- Pharming (域名欺骗): Redirection of legitimate Web traffic to illegitimate site / 将合法Web流量重定向到非法站点
- Clickjacking (点击劫持): UI redirect attack tricking users into clicking hidden elements / UI重排攻击欺骗用户点击隐藏元素
- Prompt Injection (提示注入): Manipulating LLM output via direct or indirect prompt manipulation / 通过直接或间接提示操纵LLM输出
- Social Engineering (社会工程学): Using social skills to convince people to reveal credentials / 利用社交技巧诱使人们泄露凭证
- SQL Injection (SQL注入): Injecting malicious SQL code / 注入恶意SQL代码
- Ransomware (勒索软件): Encrypting victim's data and demanding ransom / 加密受害者数据并索要赎金
- Crimeware-as-a-Service (犯罪即服务): Renting attack tools and infrastructure / 租用攻击工具和基础设施

Session 2: InfoSec Management Principles & Threat Analysis / 管理原则与威胁分析

Company Business Analysis (企业业务分析)

- Definition / 定义: Essential for understanding the company's situation and its security requirements / 对于理解企业状况及其安全需求至关重要
- Key Tools / 关键工具:
- SWOT Analysis (SWOT分析): Strengths, Weaknesses, Opportunities, Threats / 优势、劣势、机会、威胁
- Porter's Five Forces Model (波特五力模型): Competition intensity, threat of new entrants, supplier bargaining power, customer bargaining power, threat of substitute products / 竞争强度、新进入者威胁、供应商议价能力、客户议价能力、替代品威胁

Mission, Vision, and Values Statements / 使命、愿景和价值观声明

- Mission Statement (使命声明): Declares the business and intended areas of operations / 声明业务和运营领域
- Vision Statement (愿景声明): Idealistic expression of what the organization wants to become / 组织想成为什么理想化表达
- Values Statement (价值观声明): Formal set of organizational principles and qualities / 正式的组织原则和品质集合

The Six Ps of InfoSec Management / 信息安全管理的六个P

- Planning (规划): Incident response, BCP, DRP, policy, personnel, technology rollout, risk management, SETA / 事件响应、BCP、DRP、策略、人员、技术推行、风险管理、SETA
- Policy (策略): EISP, ISSP, SysSPs / 企业信息安全策略、问题特定策略、系统特定策略
- Programs (项目): SETA program, physical security program / SETA项目、物理安全项目
- Protection (保护): Risk management activities, protection mechanisms, technologies, tools / 风险管理活动、保护机制、技术、工具
- People (人员): Most critical link in the security program / 安全项目中最关键的环节
- Project Management (项目管理): Managing security projects effectively / 有效管理安全项目

Michael Whitman's 12 Categories of Threats / Michael Whitman的12类威胁

- Compromises to intellectual property (知识产权侵害): Piracy, copyright infringement / 盗版、版权侵权
- Deviations in quality of service (服务质量偏差): ISP, power, WAN issues / ISP、电力、WAN问题
- Espionage or trespass (间谍或入侵): Unauthorized access, shoulder surfing / 未授权访问、偷窥
- Forces of nature (自然灾害): Fire, flood, earthquake, lightning / 火灾、洪水、地震、闪电
- Human error or failure (人为错误或失误): Accidents, employee mistakes / 事故、员工失误
- Information extortion (信息勒索): Ransomware, blackmail / 勒索软件、敲诈
- Sabotage or vandalism (蓄意破坏或恶意损毁): Website defacement, system destruction / 网站篡改、系统破坏

- Software attacks (软件攻击): Viruses, worms, Trojans, phishing, XSS / 病毒、蠕虫、木马、钓鱼、XSS
- Technical hardware failures or errors (技术硬件故障或错误): Equipment failure, obsolescence / 设备故障、老化
- Technical software failures or errors (技术软件故障或错误): Bugs, trap doors, vulnerabilities / 漏洞、后门、脆弱性
- Technological obsolescence (技术过时): Outdated infrastructure, Windows XP example / 过时基础设施
- Theft (盗窃): Physical theft of equipment/data / 设备/数据物理盗窃
- OWASP Top 10 (2017) / OWASP十大风险
 - Injection / 注入
 - Broken authentication / 破损的身份认证
 - Cross-site scripting (XSS) / 跨站脚本
 - Broken access control / 破损的访问控制
 - Security misconfiguration / 安全配置错误
 - Sensitive data exposure / 敏感数据泄露
 - Insufficient attack protection / 攻击防护不足
 - Cross-site request forgery (CSRF) / 跨站请求伪造
 - Using components with known vulnerabilities / 使用已知漏洞组件
 - Underprotected APIs / 保护不足的API

Session 3: Cryptology / 密码学

Cryptography vs. Cryptanalysis / 密码学与密码分析

- Cryptography (密码学): From Greek "kryptos" (hidden) + "graphein" (to write) — processes of encoding and decoding messages / 来自希腊语"隐藏"+"书写", 编码和解码消息的过程
- Cryptanalysis (密码分析): From "analysein" (to break up) — deciphering messages without knowing algorithms and keys / 来自"分解", 在不知道算法和密钥的情况下破译消息

Symmetric Encryption (对称加密)

- Definition / 定义: Same algorithm and key used for both encryption and decryption (private key encryption) / 使用相同算法和密钥进行加密和解密(私钥加密)
- Advantages / 优点: Extremely efficient, fast processing / 极其高效, 处理速度快
- Challenge / 挑战: Key distribution must be done out-of-band / 密钥分发必须带外进行
- Key Algorithms / 关键算法:
 - DES: 64-bit block size, 56-bit key / 64位块大小, 56位密钥
 - 3DES (Triple DES): Uses three rounds of DES, up to 168-bit key / 使用三轮DES, 最高168位密钥
 - AES: Replaced DES, supports 128, 192, 256-bit keys / 替代DES, 支持128、192、256位密钥

Asymmetric Encryption (非对称加密)

- Definition / 定义: Uses two different but related keys (public key and private key) / 使用两个不同但相关的密钥(公钥和私钥)
- Public Key (公钥): Shared with everyone / 与所有人共享
- Private Key (私钥): Kept secret by owner / 由所有者保密
- Key Algorithm / 关键算法: RSA — most popular asymmetric encryption / 最流行的非对称加密
- Disadvantage / 缺点: 100-1,000 times slower than DES / 比DES慢100-1000倍

Digital Signatures (数字签名)

- Definition / 定义: Encrypted message digest that proves message integrity and sender authenticity / 证明消息完整性和发送者真实性的加密消息摘要
- Process / 过程: Sender creates digest → encrypts with private key → receiver decrypts with sender's public key → compares digests / 发送方创建摘要→用私钥加密→接收方用发送方公钥解密→比较摘要

Hybrid Systems (混合系统)

- Definition / 定义: Combines symmetric and asymmetric encryption / 结合对称和非对称加密
- Diffie-Hellman Key Exchange (Diffie-Hellman密钥交换): Exchanges symmetric keys using public key encryption / 使用公钥加密交换对称密钥
- Practical Method / 实际方法: Use DES/symmetric to encrypt message with random session key, then use RSA to encrypt the session key / 用DES/对称加密以随机会话密钥加密消息, 然后用RSA加密会话密钥

Managing Cryptographic Controls / 管理加密控制

- Don't lose your keys / 不要丢失密钥
- Know who you are communicating with / 知道你在与谁通信
- Every cryptosystem has weaknesses / 每个密码系统都有弱点
- There is no security in obscurity / 模糊不等于安全
- Key management is management of people, not just technology / 密钥管理是人员管理, 不仅仅是技术管理

Session 4: Firewalls & VPN / 防火墙与VPN

Firewall (防火墙)

- Definition / 定义: A device that prevents specific information from moving between untrusted network (Internet) and trusted network / 防止特定信息在不可信网络(互联网)和可信网络之间移动的设备

Categories of Firewalls / 防火墙类别

- Packet Filtering Firewalls (包过滤防火墙):
- Examines every incoming and outgoing packet header / 检查每个进出数据包头部
- Filters based on IP address, packet type, port request / 基于IP地址、包类型、端口请求过滤
- Works at Network layer (Layer 3) / 工作在网络层
- Application Layer Proxy Firewalls (应用层代理防火墙):
- Works at Application layer; proxy server acts as intermediary / 工作在使用层; 代理服务器充当中介
- Often deployed in DMZ / 通常部署在DMZ中
- Stateful Packet Inspection (SPI) Firewalls (状态包检测防火墙):
- Tracks network connections using state table / 使用状态表跟踪网络连接
- More secure than simple packet filtering / 比简单包过滤更安全
- Unified Threat Management (UTM) Devices (统一威胁管理设备):
- Combines firewall, IDPS, VPN, antivirus, content filtering / 结合防火墙、IDPS、VPN、杀毒、内容过滤

Firewall Architectures / 防火墙架构

- Packet-filtering router (包过滤路由器): Simplest, first generation / 最简单, 第一代
- Screened host firewall (屏蔽主机防火墙): Single-homed or dual-homed / 单宿主或双宿主
- Screened subnet firewall (DMZ) (屏蔽子网防火墙): Most secure implementation / 最安全的实现

DMZ (Demilitarized Zone / 非军事区)

- Definition / 定义: A segment of network between the internal network and external network / 内部网络和外部网络之间的网段
- Purpose / 目的: Houses public-facing servers (web, mail, DNS) / 托管面向公众的服务器

VPN (Virtual Private Network / 虚拟专用网络)

- Definition / 定义: Private and secure network connection using public network infrastructure / 使用公共网络基础设施的私密安全网络连接
- Three VPN Technologies / 三种VPN技术: Trusted VPN, Secure VPN, Hybrid VPN / 可信VPN、安全VPN、混合VPN
- VPN Must Accomplish / VPN必须实现: Encapsulation, Encryption, Authentication / 封装、加密、认证
- Transport Mode (传输模式): Data within IP packet is encrypted, header is not / IP包内数据加密, 头部不加密
- Tunnel Mode (隧道模式): All traffic between two perimeter tunnel servers is encrypted / 两个边界隧道服务器之间的所有流量都加密

Session 5: IDPS & Other Security Tools / 入侵检测与其他安全工具
IDPS (Intrusion Detection and Prevention System / 入侵检测与防御系统)

- Definition / 定义: Combines detection methods from IDS with prevention capability / 结合IDS检测方法与防御能力
- IPS Prevention Methods / IPS防御方法:
 - Terminating network connection or user session / 终止网络连接或用户会话
 - Reconfiguring network devices (firewalls, routers, switches) / 重新配置网络设备

- Changing attack content to make it benign / 更改攻击内容使其无害

Types of IDPS / IDPS类型

- Network-Based IDPS (NIDPS) (基于网络的IDPS):
- Monitors network traffic, looks for attack patterns / 监控网络流量, 寻找攻击模式
- Signature matching for known attacks / 签名匹配已知攻击
- Advantages: Fewer devices monitor large network, passive deployment / 优点: 少量设备监控大网络、被动部署
- Disadvantages: More false positives, cannot analyze encrypted traffic / 缺点: 更多误报、无法分析加密流量
- Host-Based IDPS (HIDPS) (基于主机的IDPS):
- Monitors activity on a specific host (web server, database) / 监控特定主机上的活动
- Examines system logs, file integrity, process activity / 检查系统日志、文件完整性、进程活动

IDPS Detection Methods / IDPS检测方法

- Signature-Based (基于签名): Compares traffic to known attack patterns / 将流量与已知攻击模式比较
- Statistical Anomaly-Based (基于统计异常): Establishes baseline, detects deviations / 建立基线, 检测偏差
- Statistical Packet Inspection (状态包检测): Tracks connection state / 跟踪连接状态

Other Security Tools / 其他安全工具

- Packet Sniffers (数据包嗅探器): Capture and analyze network traffic / 捕获和分析网络流量
- Content Filters (内容过滤器): Block inappropriate content / 阻止不当内容
- Protocol Analyzers (协议分析器): Analyze network protocols / 分析网络协议

Authentication Methods / 认证方法

- Something a Person Knows (知道什么): Passwords, passphrases, PINs / 密码、口令短语、PIN码
- Something a Person Has (拥有什么): Smart cards, tokens (synchronous/asynchronous) / 智能卡、令牌(同步/异步)
- Something a Person Can Produce (能产生什么): Biometrics — fingerprint, retina, iris / 生物识别——指纹、视网膜、虹膜

Biometric Evaluation Criteria / 生物识别评估标准

- False Reject Rate / Type I Error (错误拒绝率/I类错误): Legitimate user rejected / 合法用户被拒绝
- False Accept Rate / Type II Error (错误接受率/II类错误): Impostor accepted / 冒充者被接受
- Crossover Error Rate (CER) (交叉错误率): Point where Type I and Type II error rates are equal / I类和II类错误率相等的点

Session 6: Information Security Policy / 信息安全策略

Why Policy? / 为什么需要策略?

- Policy is the essential foundation of an effective information security program / 策略是有效信息安全项目的基础
- Rules: Policy should never conflict with law; must stand up in court; must be properly supported and administered / 规则: 策略不应与法律冲突; 必须经得起法庭检验; 必须得到适当支持和管理

Bull's-Eye Model (靶心模型)

- Layers from outside to inside / 从外到内的层次: Policies → Networks → Systems → Applications / 策略→网络→系统→应用
- Policies are the first layer of defense / 策略是第一道防线

Policy, Standards, and Practices / 策略、标准与实践

- Policy (策略): Organizational guidelines dictating certain behavior / 规定特定行为的组织准则
- Standard (标准): Detailed statement of what must be done to comply with policy / 关于必须做什么以遵守策略的详细声明
- Guidelines (指南): Nonmandatory recommendations / 非强制性建议
- Procedures (程序): Step-by-step instructions for complying with policy / 遵守策略的分步说明

Three Categories of InfoSec Policy / 信息安全策略的三类

- EISP (Enterprise Information Security Policy) (企业信息安全策略):
- High-level strategic policy / 高层策略策略
- Dresses all other policies / 驱动所有其他策略
- ISSP (Issue-Specific Security Policy) (问题特定安全策略):
- Addresses specific technology or issue / 解决特定技术或问题
- e.g., email policy, internet use policy / 例如邮件策略、互联网使用策略
- SysSP (System-Specific Policy) (系统特定策略):
- Configurations and access control for specific systems / 特定系统的配置和访问控制
- Includes ACLs (Access Control Lists) / 包括访问控制列表

Policy Life Cycle / 策略生命周期

- Development → Implementation → Enforcement → Review & Modification → Maintenance / 开发→实施→执行→审查与修改→维护
- Policy should be reviewed at least annually / 策略应至少每年审查一次

Three Causes of Unethical/Illegal Behavior / 不道德/违法行为的三大原因

- Ignorance (无知): Not knowing the rules / 不知道规则
- Accident (意外): Unintentional violation / 无意违反
- Intent (故意): Deliberate violation / 故意违反

Deterrence Conditions / 威慑条件

- Fear of penalty / 对惩罚的恐惧
- Probability of being apprehended / 被抓获的概率
- Probability of penalty being applied / 惩罚被执行的概率

Session 7: IT Risk Management / IT风险管理

Risk Management Framework / 风险管理框架

- Definition / 定义: Process of discovering and assessing risks and determining how they can be controlled or mitigated / 发现和评估风险并确定如何控制或缓解的过程
- Key Questions / 关键问题:
 - Where and what is the risk (risk identification)? / 风险在哪里, 是什么(风险识别)?
 - How severe is the risk (risk analysis)? / 风险有多严重(风险分析)?
 - Is the risk level acceptable (risk evaluation)? / 风险水平是否可接受(风险评估)?
 - What to do to bring risk to acceptable level (risk treatment)? / 如何将风险降至可接受水平(风险处置)?

RM Framework vs. RM Process / 风险管理框架 vs. 风险管理过程

- RM Framework / RM框架: Overall structure of strategic planning and design / 战略规划 and 设计的整体结构
- RM Process / RM过程: Implementation of risk management / 风险管理的实施
- Both are continuous improvement activities / 两者都是持续改进活动

Risk Management Process Steps / 风险管理过程步骤

- Establishing the context / 建立背景
- Identifying risk / 识别风险
- Analyzing risk / 分析风险
- Evaluating the risk / 评估风险
- Treating the unacceptable risk / 处置不可接受的风险
- Summarizing the findings / 总结发现

Risk Identification / 风险识别

- Identify assets, threats, and vulnerabilities / 识别资产、威胁和脆弱性
- Create inventory of information assets / 创建信息资产清单
- Classify and categorize assets / 分类和归类资产

Risk Analysis / 风险分析

- Qualitative Risk Analysis (定性风险分析): Uses subjective assessment / 使用主观评估
- Quantitative Risk Analysis (定量风险分析): Uses numerical values / 使用数值

Risk Treatment Strategies / 风险处置策略

- Avoidance (规避): Eliminate the risk / 消除风险
- Transference (转移): Shift risk to another entity (insurance) / 将风险转移给其他实体(保险)
- Mitigation (缓解): Reduce risk to acceptable level / 将风险降至可接受水平

4. Acceptance (接受) : Accept the risk and its consequences / 接受风险及其后果

Session 8: Security Management Standards & Models / 安全管理标准与模型

ISO 27000 Series / ISO 27000系列

- ISO/IEC 27002: Code of Practice for Information Security Management / 信息安全管理实践准则
- Originally BS 7799, then ISO/IEC 17799 / 原为BS 7799, 后为ISO/IEC 17799
- ISO/IEC 27001: Information Security Management System (ISMS) requirements / 信息安全管理体系要求
- ISO/IEC 27003-27005: Implementation guidance, metrics, risk management / 实施指南、度量、风险管理

NIST Security Models / NIST安全模型

- NIST SP 800-14: Generally Accepted Principles and Practices for Securing IT Systems / 保护IT系统的一般接受原则和实践
- NIST SP 800-18: Guide for Developing Security Plans for Federal Systems / 联邦系统安全计划开发指南
- NIST SP 800-30: Risk Management Guide for IT Systems / IT系统风险管理指南

Other Frameworks / 其他框架

- COBIT (Control Objectives for Information and Related Technologies): IT governance framework / IT治理框架
- ITIL (IT Infrastructure Library): IT service management best practices / IT服务管理最佳实践

Security Models / 安全模型

Bell-LaPadula (BLP) Confidentiality Model / Bell-LaPadula机密性模型

- Focuses on confidentiality / 关注机密性
- Simple Security Property (Read Property) (简单安全属性/读属性) : No read up — subject of lower clearance cannot read object of higher classification / 不可向上读——低许可主体不能读更高客体
- Star Property (Write Property) (星属性/写属性) : No write down — high-level subject cannot write to lower-level object / 不可向下写——高级别主体不能写低级别客体
- Principle / 原则: "No read up, no write down" / "不可向上读, 不可向下写"

Biba Integrity Model / Biba完整性模型

- Focuses on integrity / 关注完整性
- Simple Integrity Property (简单完整性属性) : Subject can only read objects at equal or higher integrity level / 主体只能读同级或更高级完整性的客体
- Integrity Star Property (完整性星属性) : Subject can only write to objects at equal or lower integrity level / 主体只能写同级或更低完整性的客体
- Principle / 原则: "No read down, no write up" / "不可向下读, 不可向上写"

Clark-Wilson Integrity Model / Clark-Wilson完整性模型

- Built on change control principles, designed for commercial environments / 基于变更控制原则, 为商业环境设计
- Three Change Control Principles / 三大变更控制原则:
 - No changes by unauthorized subjects / 未授权主体不可更改
 - No unauthorized changes by authorized subjects / 已授权主体不可进行未授权更改
- Maintenance of internal and external consistency / 维护内外部一致性
- Key Elements / 关键要素:
 - CDI (Constrained Data Item) (受约束数据项) : Data with protected integrity
 - UDI (Unconstrained Data Item) (不受约束数据项) : Data not controlled by Clark-Wilson
 - IVP (Integrity Verification Procedure) (完整性验证程序) : Confirms data integrity
 - TP (Transformation Procedure) (转换程序) : Only allows changes to CDI

Session 9: Information Security Planning / 信息安全规划

Precursors to Planning / 规划前提

- Mission Statement (使命声明) : What the organization does and for whom / 组织做什么, 为谁做
- Vision Statement (愿景声明) : Where the organization wants to go / 组织想去哪里
- Values Statement (价值观声明) : Organizational principles and qualities / 组织原则和品质

Strategic Planning / 战略规划

- Definition / 定义: Process of defining long-term direction and allocating resources / 定义长期方向和分配资源的过程
- Translates general strategy into specific strategy / 将总体战略转化为具体战略
- Converts strategic goals into tactical and operational planning / 将战略目标转化为战术和运营规划

Components of a Strategic Plan / 战略规划组成部分

1. Executive Summary / 执行摘要
2. Mission, Vision, and Values Statements / 使命、愿景和价值观声明
3. Organizational Profile and History / 组织概况和历史
4. Strategic Issues and Challenges / 战略问题和挑战
5. Organizational Goals and Objectives / 组织目标和目的
6. Major Business Unit Goals and Objectives / 主要业务单位目标和目的
7. Appendices / 附录

Contingency Planning / 应急规划

- Incident Response Planning (IRP) (事件响应规划) : Immediate response to security incidents / 对安全事件的即时响应
- Disaster Recovery Planning (DRP) (灾难恢复规划) : Reestablishing operations at the primary site after a disaster / 灾后可在主站点重新建立运营
- Business Continuity Planning (BCP) (业务连续性规划) : Ensuring critical business functions continue during disaster / 确保灾难期间关键业务功能继续

Business Resumption Planning (BRP) / 业务恢复规划

- Merges DR and BC plans into a single comprehensive function / 将灾难恢复和业务连续性计划合并为一个综合功能
- Supports reestablishment at alternate site AND eventually at primary site / 支持在备用站点和最终在主站点重新建立运营

Continuity Strategies / 连续性策略

- Exclusive-use options / 专用选项: Hot sites, Warm sites, Cold sites / 热站、温站、冷站
- Shared-use options / 共享选项: Timeshare, Service bureaus, Mutual agreements / 分时共享、服务局、互惠协议
- Specialized options / 专用选项: Rolling mobile site, Externally stored resources / 移动站点、外部存储资源

Session 10: Security Controls, Audit, Law & Ethics / 安全控制、审计、法律与伦理

Types of Audit / 审计类型

1. Internal Audits (内部审计) : Auditing your own organization; findings not shared outside / 审计自己组织; 发现不外泄
2. External Audits (外部审计) : Customer audits your org, or you audit supplier/customer / 客户审计你, 或你审计供应商/客户
3. Independent Audits (独立审计) : For licensing, certification, product approval / 用于许可、认证、产品批准

IS Auditing / 信息系统审计

- Definition / 定义: Collecting and evaluating evidence to determine whether a system safeguarding assets, maintains data integrity, achieves organizational goals effectively, and uses resources efficiently / 收集和评估证据以确定系统是否保护资产、维护数据完整性、有效实现组织目标并高效使用资源
- Primary Task / 主要任务: Evaluate whether controls operate effectively / 评估控制是否有效运作

Controls Framework / 控制框架

- Levels of Controls / 控制层级:

- Preventive Controls (预防性控制) : Prevent unlawful events from occurring / 防止非法事件发生
- Detective Controls (检测性控制) : Detect unlawful events after they occur / 在非法事件发生后检测
- Corrective Controls (纠正性控制) : Correct the effects of unlawful events / 纠正非法事件的影响
- Controls Categories / 控制分类:
 - Management Controls (管理控制) : Policies, procedures, organization and management / 策略、程序、组织和管理
- Application Controls (应用控制) : Input, processing, output controls / 输入、处理、输出控制

Privacy Laws / 隐私法律

- HIPAA (Health Insurance Portability and Accountability Act, 1996) (健康保险可携性和责任法案) : Protects confidentiality and security of healthcare data / 保护医疗数据的机密性和安全性
- Hong Kong Data Protection Principles / 香港数据保护原则:
 - DPP1 - Data Collection Principle / 数据收集原则
 - DPP2 - Accuracy & Retention Principle / 准确性与保留原则
 - DPP3 - Data Use Principle / 数据使用原则
 - DPP4 - Data Security Principle / 数据安全原则
 - DPP5 - Openness Principle / 开放性原则
 - DPP6 - Data Access & Correction Principle / 数据访问与更正原则

U.S. Copyright Law / 美国版权法

- Extends protection to intellectual property including electronic formats / 将保护扩展到包括电子格式的知识产权
- Fair Use Doctrine (合理使用原则) : Allows quoting for news reporting, teaching, scholarship / 允许为新闻报道、教学、学术引用

Sarbanes-Oxley (SOX) Act of 2002 / 萨班斯-奥克斯利法案

- Enforces accountability for financial record keeping / 强制财务记录保存的问责
- CEO and CFO assume direct and personal accountability / CEO和CFO承担直接和个人的问责
- Must maintain availability and confidentiality of information / 必须维护信息的可用性和机密性

3. Key Formulas & Theorems / 重点公式与定理

Annualized Loss Expectancy (ALE) / 年度损失期望

- Formula / 公式:
$$ALE = SLE \times ARO$$
- Variables / 变量说明:
 - ALE (Annualized Loss Expectancy) / 年度损失期望: Expected annual loss from a risk / 某风险的预期年度损失
 - SLE (Single Loss Expectancy) / 单次损失期望: Loss from a single occurrence / 单次发生的损失
 - ARO (Annualized Rate of Occurrence) / 年度发生率: How often the attack is expected per year / 预期每年发生攻击的次数
 - Conditions / 适用条件: Used in quantitative risk analysis to prioritize risk treatment / 用于定量风险分析以优先处理风险

Single Loss Expectancy (SLE) / 单次损失期望

- Formula / 公式:
$$SLE = AV \times EF$$
- Variables / 变量说明:
 - AV (Asset Value) / 资产价值: Value of the information asset / 信息资产的价值
 - EF (Exposure Factor) / 暴露系数: Percentage of asset lost in a single attack / 单次攻击中资产损失的百分比
 - Conditions / 适用条件: Must be calculated before ALE / 必须在计算ALE之前计算

Cost-Benefit Analysis (CBA) / 成本效益分析

- Formula / 公式:
$$CBA = ALE_{(precontrol)} - ALE_{(postcontrol)} - ACS$$
- Variables / 变量说明:
 - ALE(precontrol) / 控制前ALE: ALE before implementing the control / 实施控制前的ALE
 - ALE(postcontrol) / 控制后ALE: ALE after the control has been in place / 实施控制后的ALE
 - ACS (Annualized Cost of Safeguard) / 年度防护成本: Annual cost of implementing and maintaining the control / 实施和维护控制的年度成本
 - Conditions / 适用条件: CBA > 0 means the control is cost-effective / CBA > 0 表示控制具有成本效益

4. Typical Questions & Solutions / 典型例题与解答

Question 1: SWOT Analysis / SWOT分析 (Written Exercise #1)

Problem / 问题: Based on City University of Hong Kong (Dongguan campus), perform a comprehensive business situation analysis using SWOT analysis with five paragraphs: Background, Strengths, Weaknesses, Opportunities, and Threats.

Solution / 解答思路:

- Background / 背景: Describe the organization — CityU DG is a newly established campus in Dongguan, China, offering undergraduate and postgraduate programs. It benefits from the Greater Bay Area development and mainland-HK educational cooperation.
- Strengths / 优势:
 - Strong academic reputation from CityU Hong Kong (top 100 globally) / 来自香港城市大学的强大声誉
 - Access to both mainland China and Hong Kong resources / 可利用内地和香港资源
 - Government support from Greater Bay Area initiative / 大湾区政策的政府支持
 - Modern campus with state-of-the-art facilities / 拥有先进设施的现代化校园
- Weaknesses / 劣势:
 - New campus with limited brand recognition in mainland / 新校园在内地的品牌知名度有限
 - Limited alumni network compared to established universities / 与老牌大学相比校友网络有限
 - Dependence on HK-based administrative systems / 依赖香港的行政系统
 - Small faculty size in early stages / 早期师资队伍规模较小
 - Opportunities / 机会:
 - Growing demand for quality higher education in Greater Bay Area / 大湾区对优质高等教育的需求增长
 - Government policies supporting cross-border education / 政府支持跨境教育的政策
 - Industry partnerships for research and employment / 产业合作促进研究和就业
 - Technology hub development in Dongguan / 东莞科技中心的发展
 - Threats / 威胁:
 - Competition from established mainland universities / 来自成熟内地大学的竞争
 - Regulatory changes in cross-border education / 跨境教育监管变化
 - Cybersecurity risks from being a cross-border institution / 跨境机构面临的网络安全风险
 - Geopolitical tensions affecting HK-mainland cooperation / 地缘政治紧张影响港陆合作

Question 2: Threat Analysis / 威胁分析 (Written Exercise #2)

Problem / 问题: Based on CityU Dongguan, perform a threat analysis using Michael Whitman's 12-category of threats. Each paragraph should show each threat analysis with concrete examples and diagrams.

- Solution / 解答思路 (Key categories with examples for CityU DG):
1. Compromises to IP / 知识产权侵害: Research publications, proprietary course materials could be plagiarized; online course content piracy / 研究论文、专有课程材料可能被剽窃
 2. QoS Deviations / 服务质量偏差: Internet outages, power failures affecting online teaching systems / 互联网中断、停电影响在线教学系统
 3. Espionage / 间谍: Unauthorized access to research data, industrial espionage targeting university-industry collaborations / 未授权访问研究数据

4. Forces of Nature / 自然力量: Guangdong province is prone to typhoons and flooding / 广东省易受台风和洪水影响
5. Human Error / 人为错误: Students accidentally deleting files, faculty misconfiguring systems / 学生误删文件、教师误配置系统
6. Information Extortion / 信息勒索: Ransomware attacks on university databases containing student records / 针对包含学生记录的大学数据库的勒索软件攻击
7. Sabotage / 蓄意破坏: Website defacement, system destruction by disgruntled students or staff / 网站篡改、系统破坏
8. Software Attacks / 软件攻击: Phishing emails targeting students, malware on campus network / 针对学生的钓鱼邮件、校园网络上的恶意软件
9. Hardware Failures / 硬件故障: Server crashes, network equipment failures / 服务器崩溃、网络设备故障
10. Software Failures / 软件故障: Learning management system bugs, database corruption / 学习管理系统漏洞、数据库损坏
11. Technological Obsolescence / 技术过时: Legacy systems no longer supported, outdated security software / 不再受支持的遗留系统、过时的安全软件
12. Theft / 盗窃: Laptop theft in campus, data theft by insiders / 校园笔记本电脑盗窃

Question 3: ALE Calculation / ALE计算

Problem / 问题: A website has an estimated value of \$1,000,000. A deliberate act of sabotage indicates that 10% of the website would be damaged. A successful sabotage might occur about once every two years. Calculate SLE and ALE.

Solution / 解答: $AV = \$1,000,000$ $EF = 10\% = 0.1$ $SLE = AV \times EF = 1,000,000 \times 0.1 = 100,000$ $ARO = \text{once every 2 years} = 0.5$ $ALE = SLE \times ARO = 100,000 \times 0.5 = 50,000$ The organization expects to lose 50,000 per year from this risk / 组织预期每年损失50,000

Question 4: Bell-LaPadula vs. Biba Model Comparison / BLP与Biba模型对比

Problem / 问题: Compare and contrast the Bell-LaPadula model and the Biba model.

Solution / 解答:

Feature / 特征	Bell-LaPadula (BLP)	Biba
Focus / 关注点	Confidentiality / 机密性	Integrity / 完整性
Read Rule / 读规则	No read up / 不可向上读	No read down / 不可向下读
Write Rule / 写规则	No write down / 不可向下写	No write up / 不可向上写
Environment / 环境	Military/government / 军事/政府	Commercial / 商业
Goal / 目标	Prevent information leakage / 防止信息泄露	Prevent data corruption / 防止数据污染

Question 5: Firewall Types Comparison / 防火墙类型对比

Problem / 问题: Compare the four types of firewalls.

Solution / 解答:

Type / 类型	OSI Layer / 网络层	Method / 方法	Pros / 优点	Cons / 缺点
Packet Filtering / 包过滤	Network (L3)	Header inspection / 头部检查	Fast, simple / 快速简单	Cannot inspect payload / 无法检查载荷
Application Proxy / 应用代理	Application (L7)	Full proxy service / 完整代理服务	Deep inspection / 深度检查	Slow, resource-intensive / 慢、资源消耗大
SPI / 状态包检测	Network (L3-4)	State table tracking / 状态表跟踪	More secure than packet filtering / 比包过滤更安全	More complex / 更复杂
UTM / 统一威胁管理	Multiple / 多层	All-in-one / 多功能合一	Comprehensive / 全面	Single point of failure / 单点故障

Question 6: VPN Transport Mode vs. Tunnel Mode / VPN传输模式与隧道模式

Problem / 问题: What are the differences between VPN transport mode and tunnel mode?

Solution / 解答:

Feature / 特征	Transport Mode / 传输模式	Tunnel Mode / 隧道模式
Encryption / 加密范围	Only data (payload) of IP packet / 仅IP包数据	Entire original packet / 整个原始数据包
Header / 头部	Not encrypted, original header visible / 未加密, 原始头部可见	New header added, original hidden / 添加新头部, 原始隐藏
Use Case / 使用场景	End-to-end, remote access / 端到端、远程访问	Site-to-site, gateway-to-gateway / 站点到站点
Destination visible / 目的地可见	Yes / 是	No (only tunnel endpoint visible) / 否 (仅隧道端点可见)

Question 7: Biometric Error Types / 生物识别错误类型

Problem / 问题: Explain Type I Error, Type II Error, and CER in biometrics.

Solution / 解答:

Type I Error (False Reject Rate) / I类错误 (错误拒绝率): A legitimate user is incorrectly rejected by the system. E.g., authorized employee's fingerprint not recognized / 合法用户被系统错误拒绝 - Type II Error (False Accept Rate) / II类错误 (错误接受率): An impostor is incorrectly accepted by the system. E.g., unauthorized person's fingerprint matched / 冒充者被系统错误接受 - CER (Crossover Error Rate) / 交叉错误率: The where Type I and Type II error rates are equal. Lower CER = more accurate biometric system / I类和II类错误率相等 - CER越低=生物识别系统越准确

Question 8: Risk Treatment Strategies / 风险处置策略

Problem / 问题: Describe the four risk treatment strategies with examples.

Solution / 解答:

1. Avoidance / 规避: Eliminate the risk by removing the cause. Example: Discontinuing a vulnerable web service / 通过移除原因消除风险。例如: 停止脆弱的Web服务
2. Transference / 转移: Shift risk to another entity. Example: Purchasing cybersecurity insurance / 将风险转移给其他实体。例如: 购买网络安全保险
3. Mitigation / 缓解: Reduce risk to acceptable level. Example: Implementing firewalls and IDPS / 将风险降至可接受水平。例如: 实施防火墙和IDPS
4. Acceptance / 接受: Accept the risk when cost of mitigation exceeds potential loss. Example: Accepting minor website downtime risk / 当缓解成本超过潜在损失时接受风险。例如: 接受轻微网站停机风险

Question 9: CBA Calculation / 成本效益分析计算

Problem / 问题: If ALE before a control is 50,000, ALE after the control is 10,000, and the annual cost of the safeguard is \$15,000, should the organization implement the control?

Solution / 解答: $CBA = ALE_{(precontrol)} - ALE_{(postcontrol)} - ACS$ $CBA = 50,000 - 10,000 - 15,000 = 25,000$ - Since CBA > 0, the control is cost-effective and should be implemented / 由于CBA > 0, 该控制具有成本效益, 应予实施

Question 10: Clark-Wilson Model Elements / Clark-Wilson模型要素

Problem / 问题: Explain the key elements of the Clark-Wilson integrity model.

Solution / 解答: CDI (Constrained Data Item) / 受约束数据项: Data whose integrity is protected by the model / 完整性受模型保护的 - UDI (Unconstrained Data Item) / 不受约束数据项: Data not controlled by the model, e.g., nonvalidated input / 不受模型控制的数据, 如未验证的输入 - IVP (Integrity Verification Procedure) / 完整性验证程序: Confirms that CDI data maintains its integrity at any point / 确认CDI数据在任何点都保持完整性 - TP (Transformation Procedure) / 转换程序: The only procedure allowed to change a CDI; ensures changes maintain integrity / 唯一允许更改CDI的过程, 确保更改维护完整性